Network Reconnaissance and Man-in-the-Middle Attack Simulation Report

Professional Security Assessment Format

Prepared by	Hamma Jaff
Environment	Isolated virtual lab
Primary Tools	Kali Linux, Nmap, Wireshark, SSLStrip
Document Type	Technical assessment report

Executive Summary

This report presents the results of a controlled network security assessment conducted in an isolated virtual lab environment. The assessment focused on host discovery, ARP spoofing concepts, packet capture analysis, SSL/TLS downgrade testing, and active vulnerability scanning using Kali Linux, Nmap, Wireshark, and SSLStrip.

The objective of the assessment was to evaluate how common reconnaissance and interception techniques operate within a local network, identify the type of information that can be gathered through these methods, and document the security implications of insecure communications and weak trust relationships at the network layer.

The assessment successfully demonstrated network discovery and traffic analysis procedures and documented key risks related to ARP spoofing and packet interception. SSL/TLS downgrade testing did not produce a successful HTTPS-to-HTTP downgrade under the test conditions, indicating that environmental constraints, dependency issues, or modern browser and transport protections limited the effectiveness of the downgrade attempt in the lab environment.

Overall, the results reinforce the importance of encryption, network segmentation, monitoring, and routine vulnerability management as core controls for reducing exposure to interception-based attacks.

Introduction

This assessment was performed in a controlled virtual lab environment to demonstrate foundational cybersecurity concepts relevant to network security, desktop support, and systems administration. The engagement focused on identifying active systems, understanding ARP spoofing and man-in-the-middle attack mechanics, capturing and reviewing traffic with Wireshark, testing SSL/TLS downgrade behavior, and analyzing vulnerability scanning activity using Nmap.

The assessment was designed to show how reconnaissance and interception techniques can be used to identify network assets, observe communication patterns, and evaluate the exposure created by plaintext traffic or insecure protocol behavior. In addition, the assessment documented how encryption and host or network protections affect attack feasibility and reduce the visibility of intercepted traffic.

Assessment Snapshot

Target Subnet	192.168.3.0/24
Active Hosts Identified	5 hosts
Primary Analysis Focus	Discovery, interception concepts, packet analysis, downgrade testing, scanning
Assessment Constraints	SSL/TLS downgrade not successful under tested lab conditions

Scope

All activities conducted during this assessment remained within an isolated virtual lab environment established for authorized technical testing and analysis. The scope included network discovery across the local subnet, ARP spoofing and man-in-the-middle simulation concepts, packet capture and protocol inspection, SSL/TLS downgrade testing, and active scanning using Nmap.

The primary tools used during the assessment were Kali Linux, Nmap, Wireshark, and SSLStrip. Testing was performed solely for controlled security analysis and documentation purposes.

Methodology

The assessment followed a structured methodology intended to evaluate the visibility, interception potential, and defensive characteristics of a small lab network. The process began with host discovery and subnet analysis using Nmap to identify live systems and collect MAC address and vendor information where available. The identified systems were then used as the basis for analyzing local man-in-the-middle attack concepts and packet visibility.

Wireshark was used to capture traffic on the selected network interface in the Kali virtual machine environment, specifically eth0, in order to observe protocol behavior, ARP traffic, packet flow, and metadata associated with communications between systems. Filtering was applied where appropriate to isolate traffic relevant to the analysis.

The methodology also included an attempt to perform SSL/TLS stripping by redirecting traffic for downgrade testing. Troubleshooting steps included firewall changes, dependency validation, Python compatibility review, and port redirection adjustments. Finally, Nmap scanning techniques such as host discovery, ping sweeps, and stealth scanning were reviewed as part of the vulnerability scanning phase.

Findings and Analysis

1. Network Discovery

Nmap was used to perform host discovery within the target subnet 192.168.3.0/24. The scan identified five active hosts in the environment. The output included IP addresses, MAC address information, and vendor identification inferred from MAC address data. At this stage, the scan did not provide full service enumeration or detailed open-port analysis.

These findings demonstrate the value of initial reconnaissance in identifying active systems and defining the attack surface for further analysis. Even a basic discovery scan can support asset inventory validation, unauthorized device identification, and incident response preparation by establishing a baseline view of the local environment.

2. ARP Spoofing and Man-in-the-Middle Exposure

ARP spoofing was reviewed as a technique that uses counterfeit ARP messages to associate an attacker-controlled MAC address with the IP address of a legitimate system. This allows traffic to be redirected through the attacker and creates the conditions required for a man-in-the-middle attack within a local broadcast domain.

The primary risks associated with this technique include interception of unencrypted information, session hijacking, service disruption, malicious redirection, and instability caused by conflicting ARP mappings. In environments that rely heavily on local trust and do not monitor ARP anomalies, this technique can introduce meaningful security and operational risk.

Recommended mitigations include network segmentation, Dynamic ARP Inspection, ARP monitoring, selective use of static ARP entries for critical systems, and encryption of sensitive communications.

3. Traffic Capture and Packet Analysis

Wireshark was used to capture and inspect traffic passing through the selected interface in the Kali virtual machine environment. The packet capture process provided visibility into source and destination IP addresses, protocol usage, ARP activity, and packet timing. Filters were used to narrow the analysis to specific traffic types where needed.

The traffic analysis demonstrated that unencrypted communications may expose sensitive information such as passwords, emails, session data, or other application-layer content when transmitted over plaintext protocols. Even where the payload is encrypted, metadata such as IP addresses, timestamps, and connection behavior may still reveal useful information about user activity or system interaction patterns.

Encrypted traffic limits content visibility during interception and provides confidentiality, integrity validation, and authentication benefits. In practical terms, packet capture alone is generally not sufficient to expose protected content when properly secured transport mechanisms are in place.

4. SSL/TLS Downgrade Testing

SSL/TLS stripping was assessed as a downgrade technique intended to force browser-server communication from HTTPS to HTTP, thereby exposing sensitive traffic in plaintext. If successful, this technique could expose passwords, personal information, and session data to interception.

In this assessment, downgrade attempts were unsuccessful. HTTPS could not be downgraded to HTTP, and the expected intercepted web traffic was not captured during testing. Troubleshooting included changes to iptables to redirect traffic from port 80 to port 8081, but the intended interception did not occur. Additional steps included investigating Python 2.7 compatibility for SSLStrip, dealing with Twisted installation issues, creating a Windows Defender rule to allow port 80, and temporarily disabling private and public firewall protections on the target system.

This result is best documented as evidence that the tested environment resisted the downgrade under the conditions used. The most likely explanations are dependency limitations, host configuration issues, or modern browser and transport protections such as HSTS behavior and secure-session enforcement.

5. Vulnerability Scanning with Nmap

The vulnerability scanning portion of the assessment focused on the use of Nmap to identify weaknesses within the network infrastructure. The purpose of such scans is to detect security issues, support policy compliance, prepare for audits, and reveal exploitable conditions before they are abused by attackers.

Vulnerability scanning supports risk identification by discovering devices, checking systems against known weakness patterns, and prioritizing issues based on severity. Typical findings can include unpatched software, insecure configurations, and exposed services that increase the likelihood of compromise.

The documented activities included LAN scanning, IP host scanning, ping sweeps, and stealth scanning. Together, these activities supported both basic reconnaissance and a broader understanding of network exposure.

Recommendations

- Enforce encrypted communications across applicable services to reduce the usefulness of packet interception and protect credentials, sessions, and application data in transit.
- Strengthen controls against local interception attacks by implementing segmentation, monitoring ARP behavior for anomalies, enabling Dynamic ARP Inspection where available, and using static ARP entries selectively for critical infrastructure.
- Maintain secure transport protections such as HSTS, HSTS preloading, and secure cookie settings to reduce the likelihood of successful downgrade activity.
- Harden host and firewall configurations so that only required services are exposed and traffic paths remain restricted to approved behavior.
- Conduct ongoing vulnerability management through regular scanning, patching, correction of insecure settings, review of least-privilege access, and validation of remediation results.
- Retain screenshots, scan output, and troubleshooting evidence in an appendix to support technical review and portfolio presentation.

Conclusion

This assessment demonstrated several foundational network security concepts relevant to cybersecurity operations, systems administration, and technical support roles. Host discovery and traffic analysis provided visibility into the local lab environment, while ARP spoofing review and interception concepts highlighted the risks created by insecure network trust relationships and unencrypted communications.

Although SSL/TLS downgrade testing did not produce a successful interception result, the troubleshooting process still generated meaningful technical findings. The documented issues related to port redirection, dependency support, host firewall changes, and protocol behavior suggest that modern security controls and environmental constraints materially reduced the feasibility of the downgrade technique under the tested conditions.

Overall, the assessment reinforces the importance of encryption, segmentation, monitoring, and disciplined vulnerability management as core defenses against reconnaissance and man-in-the-middle attack paths.

These appendices contain screenshots and captions documenting key assessment activities, including host discovery, ARP spoofing, packet analysis, vulnerability scanning, and SSL/TLS troubleshooting performed in the lab environment.

Appendix A: Assessment Evidence

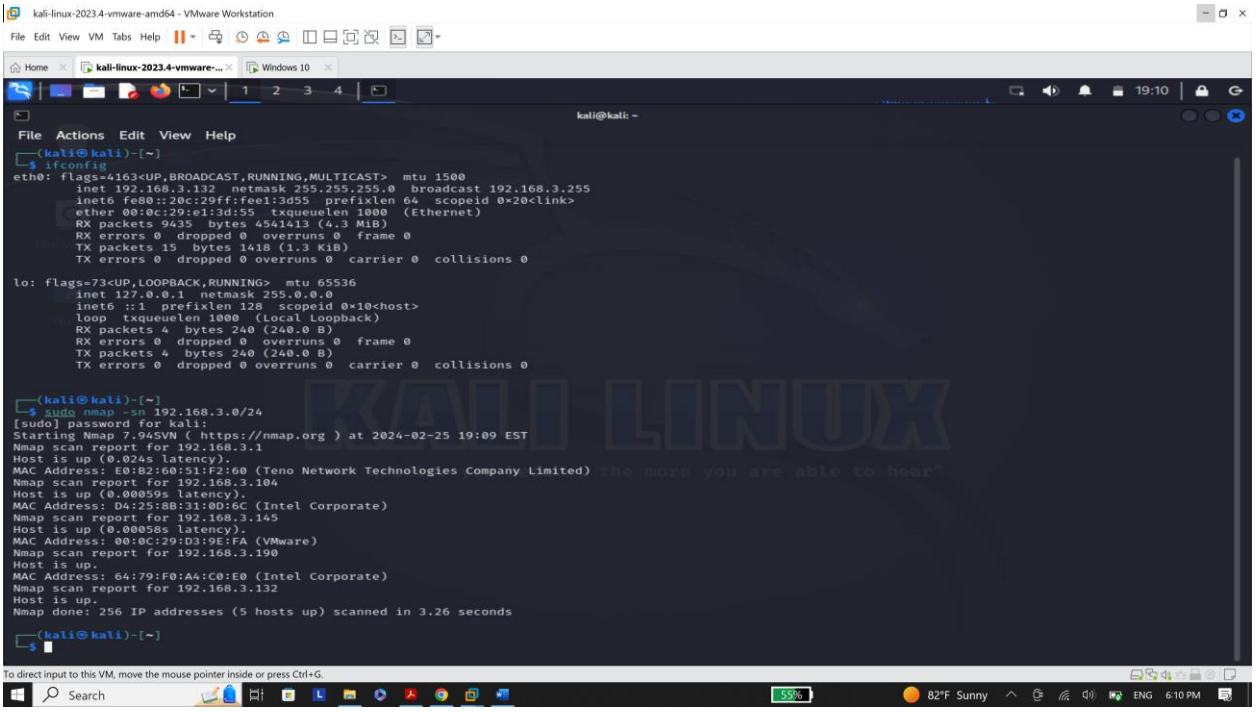

Figure A1. Kali Linux attacker workstation showing ifconfig output and an Nmap ping sweep of the 192.168.3.0/24 subnet, confirming local interface configuration and identifying five active hosts during the network discovery phase.

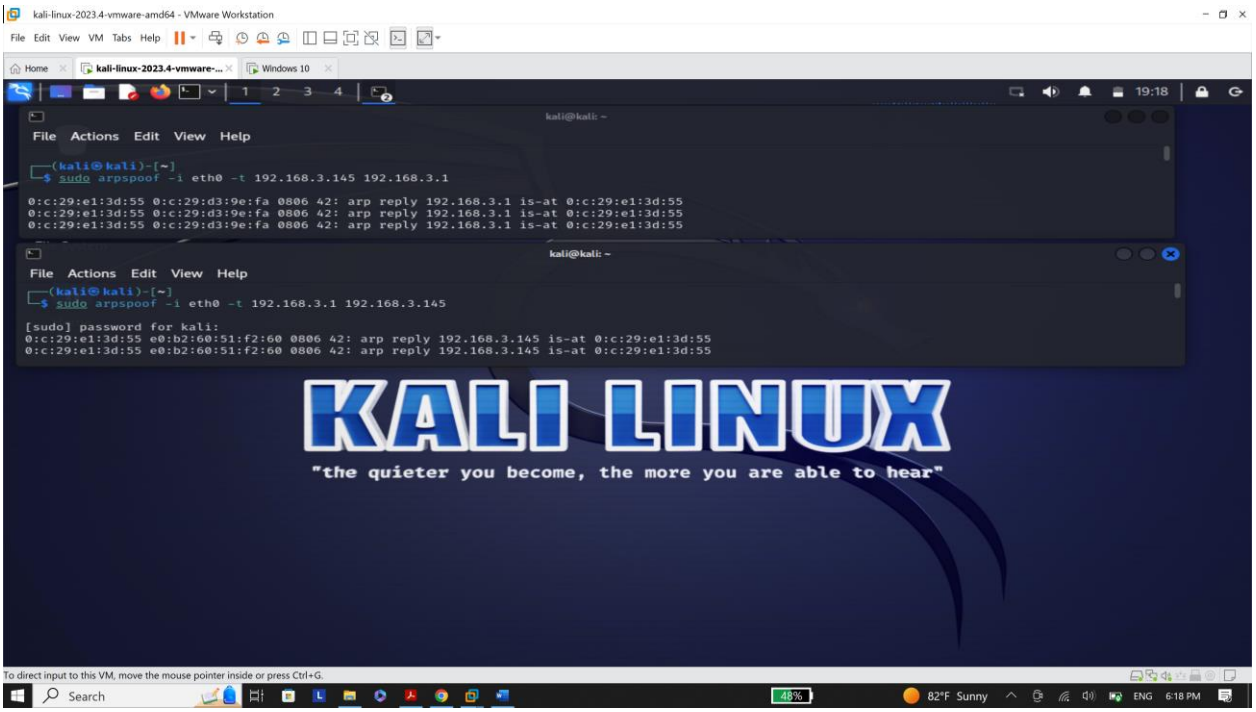

Figure A2. ARP spoofing activity on the attacker host establishing a man-in-the-middle path between the target system and the default gateway.

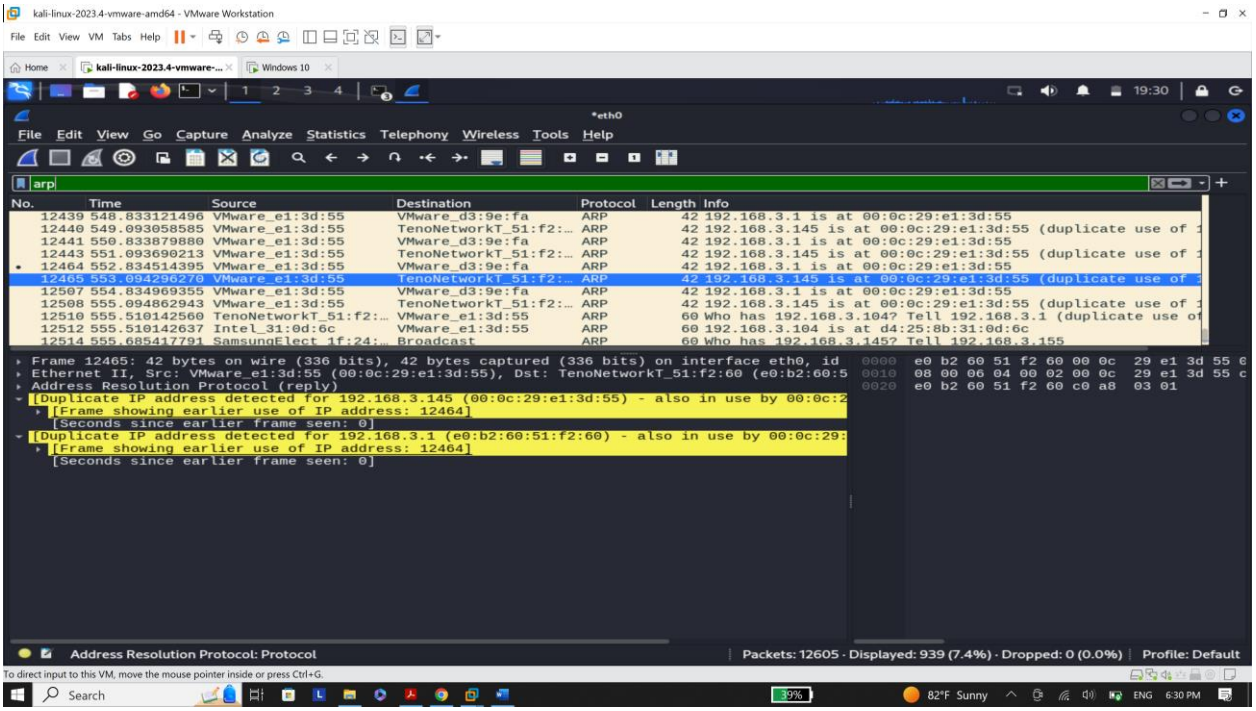

Figure A3. Wireshark packet capture on interface eth0 showing ARP replies and duplicate IP address detection during ARP spoofing activity between the target host and gateway.

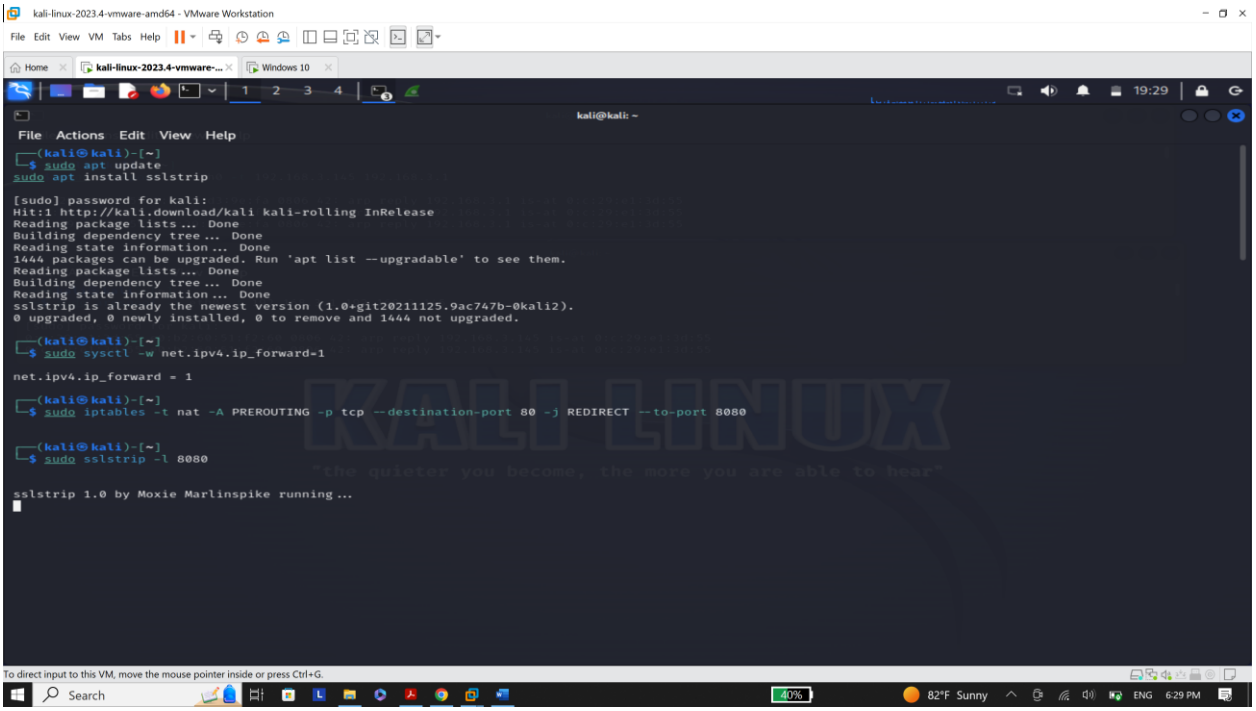

Figure A4. Kali Linux terminal showing SSLStrip preparation steps, including package validation, IP forwarding enablement, iptables port 80 to 8080 redirection, and SSLStrip execution on port 8080 during downgrade testing.

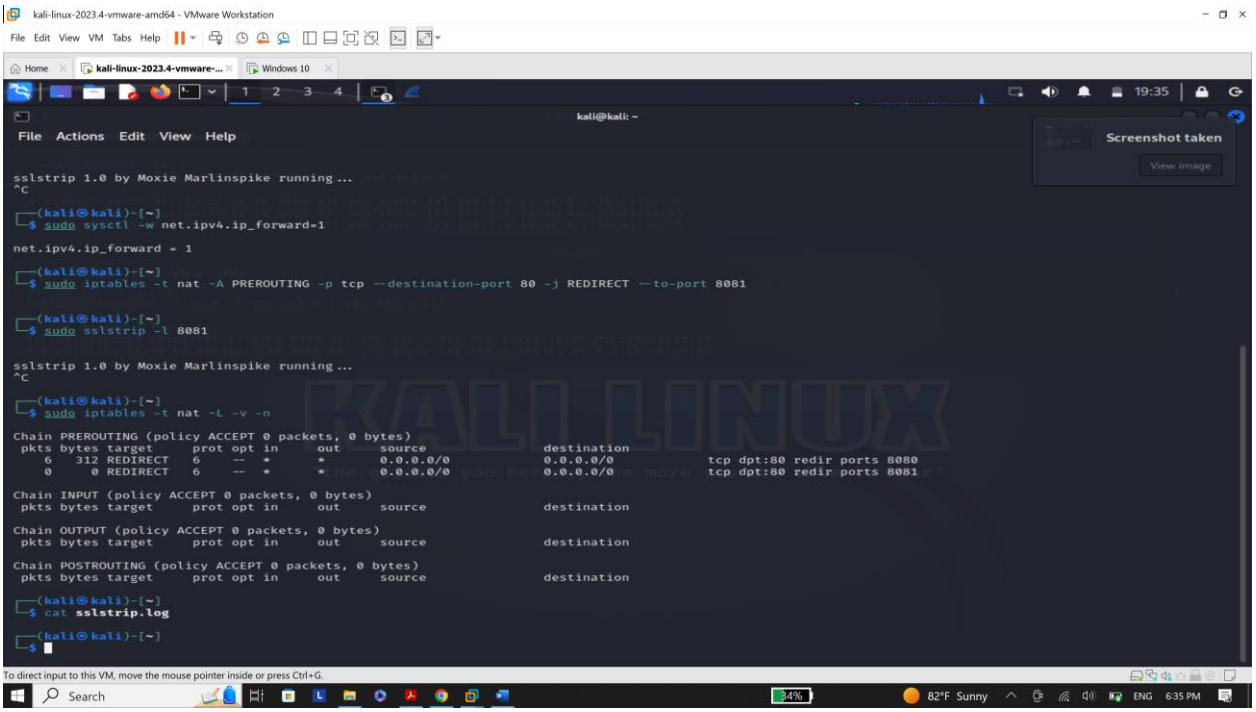

Figure A5. Kali Linux terminal showing SSLStrip execution on port 8081 and verification of iptables NAT prerouting rules used to redirect TCP port 80 traffic during SSL/TLS downgrade troubleshooting.

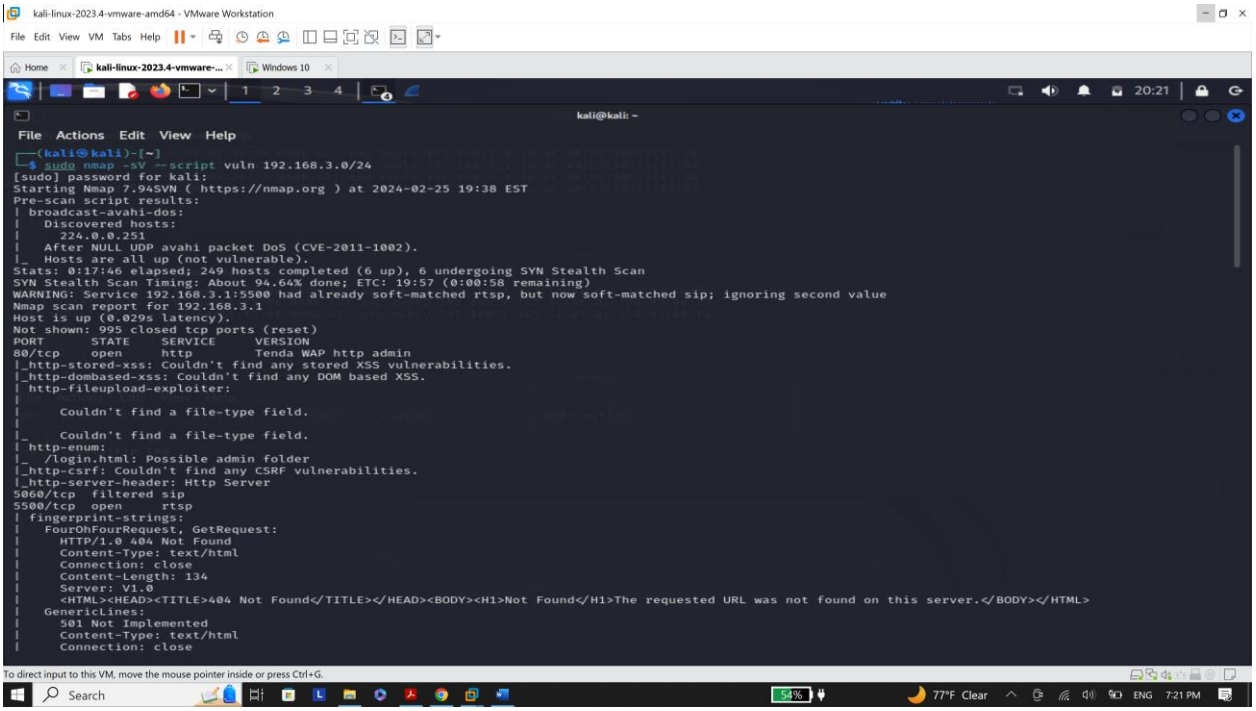

Figure A6. Kali Linux terminal showing an Nmap scan script execution against a host in the 192.168.3.0/24 subnet, identifying open ports, HTTP service details, and preliminary vulnerability enumeration results during the active scanning phase.

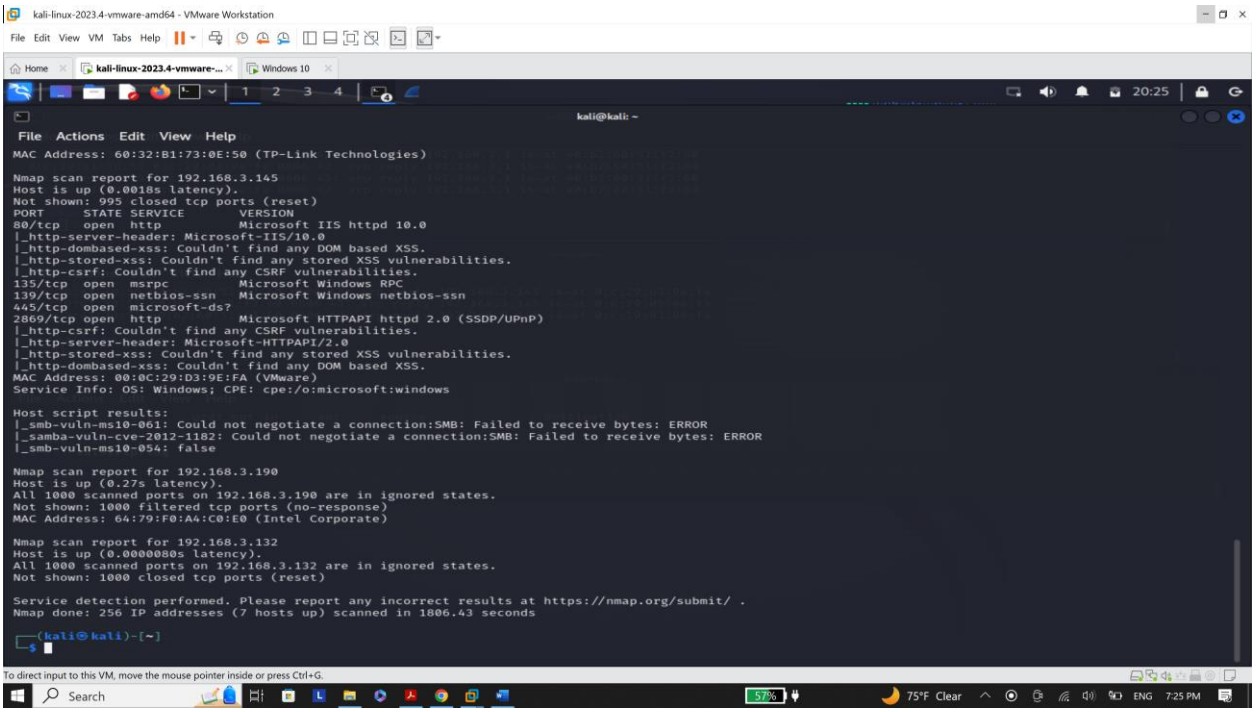

Figure A7. Kali Linux terminal showing Nmap service detection and host enumeration results, including identified open ports, Microsoft services, and filtered ports observed during active scanning of systems in the 192.168.3.0/24 lab environment.

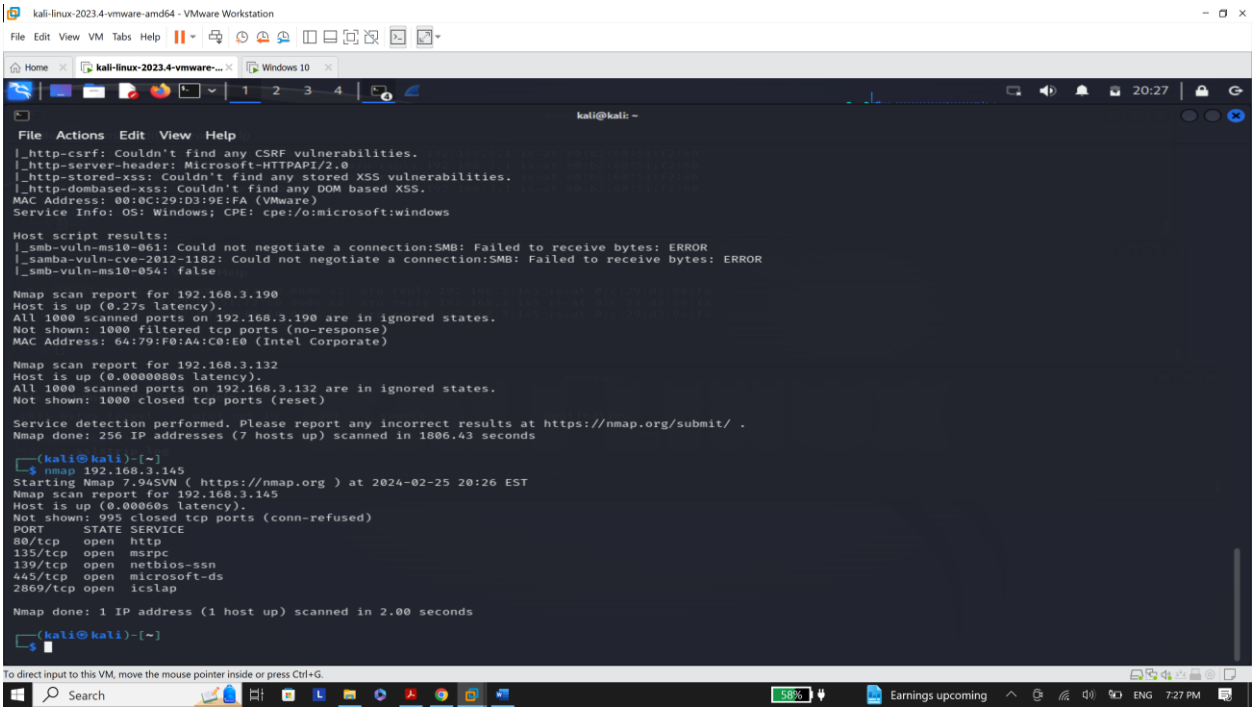

Figure A8. Kali Linux terminal showing a targeted Nmap scan of host 192.168.3.145, identifying open ports including HTTP, MSRPC, NetBIOS-SSN, Microsoft-DS, and ICSI-LAPB during service enumeration.

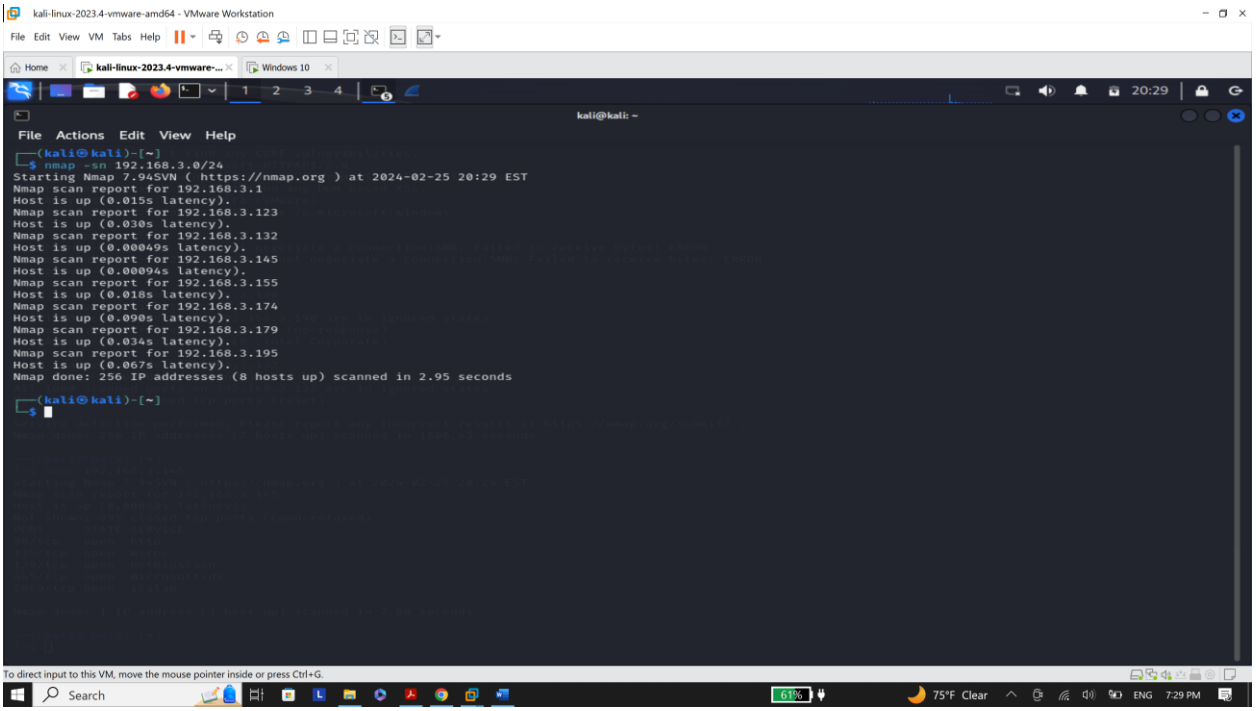

Figure A9. Kali Linux terminal showing an Nmap ping sweep of the 192.168.3.0/24 subnet, identifying multiple responsive hosts and confirming active systems during the discovery phase of the assessment.

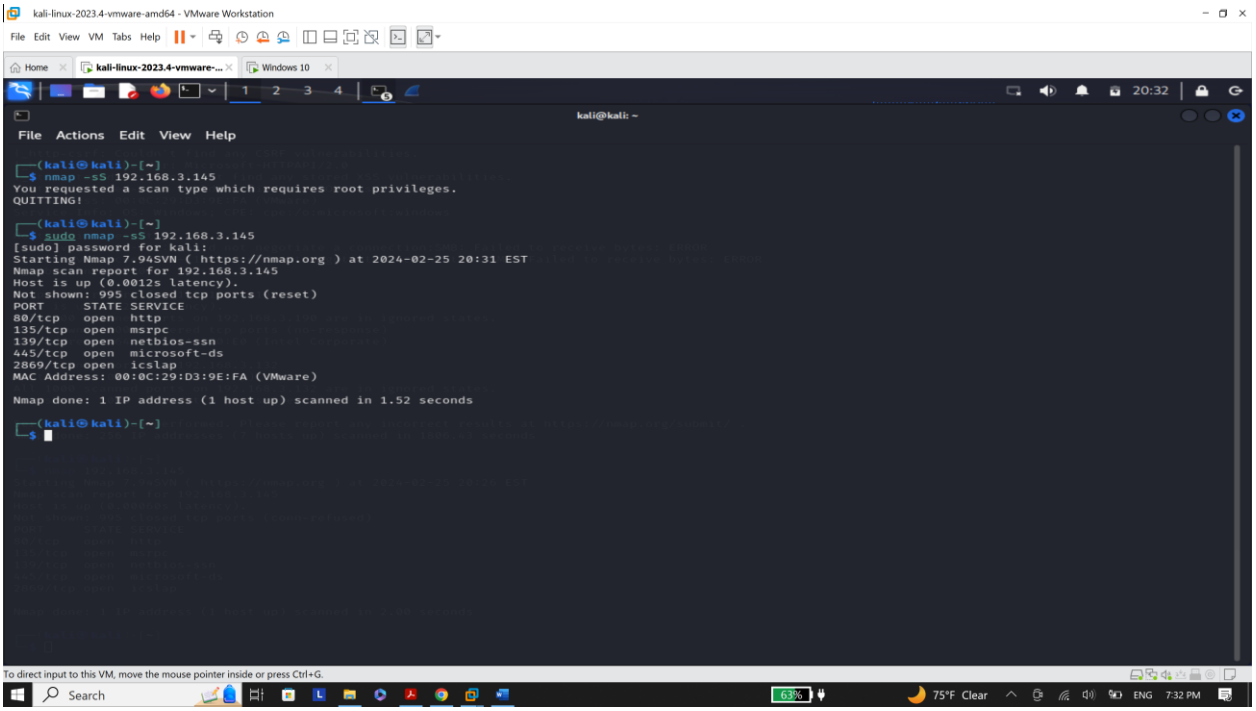

Figure A10. Kali Linux terminal showing a privileged Nmap SYN scan (-sS) against host 192.168.3.145, including an initial permission error without elevated privileges followed by successful execution with sudo and identification of open ports and services.

Appendix B: SSL/TLS Troubleshooting Evidence

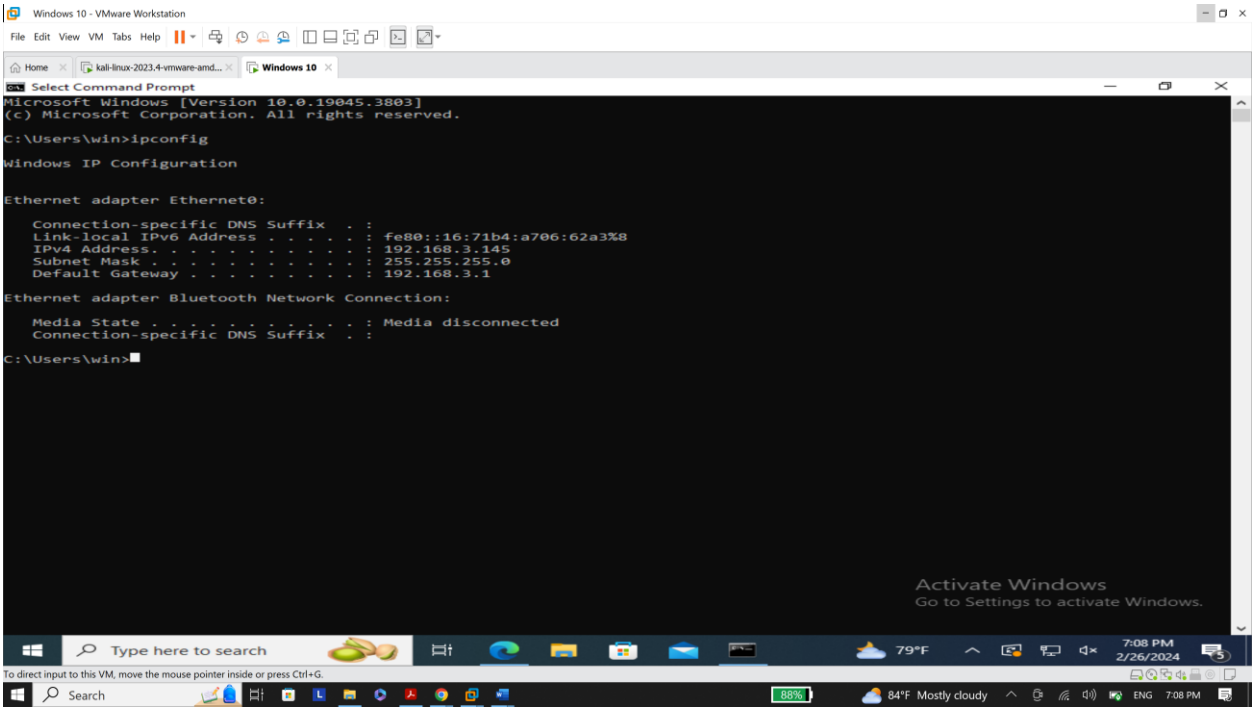

Figure B1. Windows 10 command prompt showing ipconfig output for the target system, including IPv4 address 192.168.3.145, subnet mask 255.255.255.0, and default gateway 192.168.3.1, captured as part of SSL/TLS stripping troubleshooting to validate host network configuration and routing path.

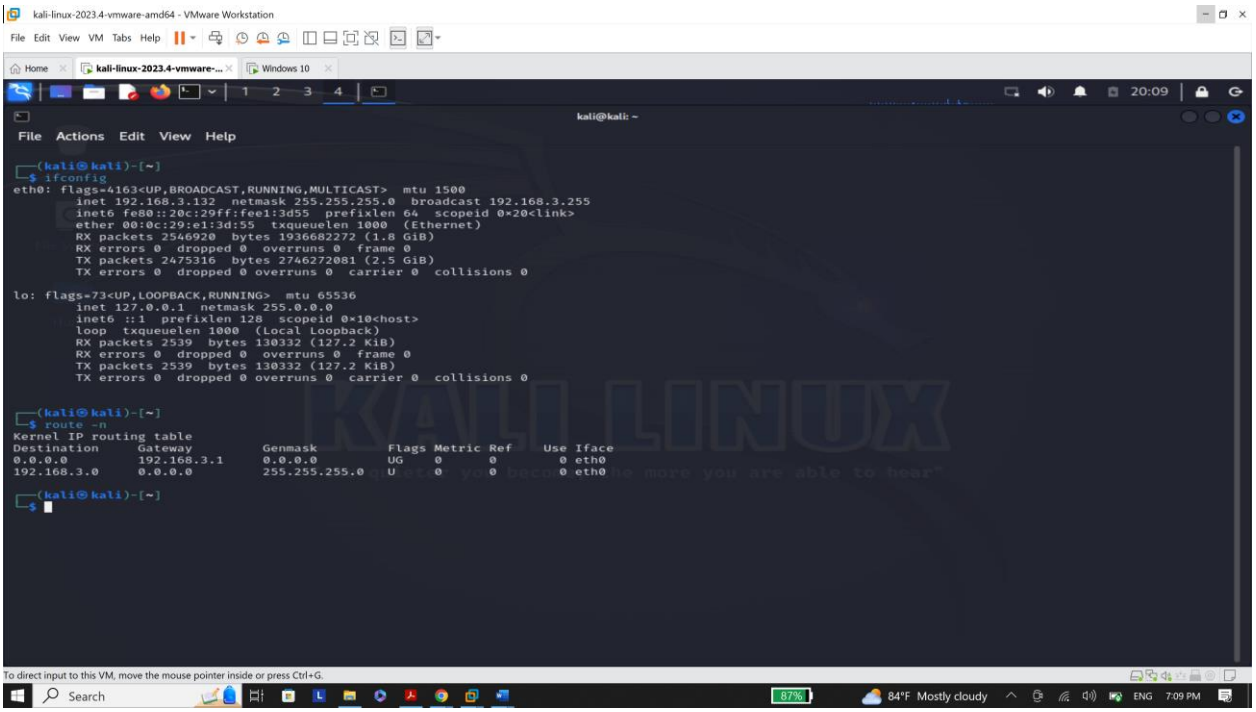

Figure B2. Kali Linux terminal showing ifconfig and route -n output for the attacker system, including interface address 192.168.3.132 and default gateway 192.168.3.1, captured during SSL/TLS stripping troubleshooting to verify network path and routing configuration.

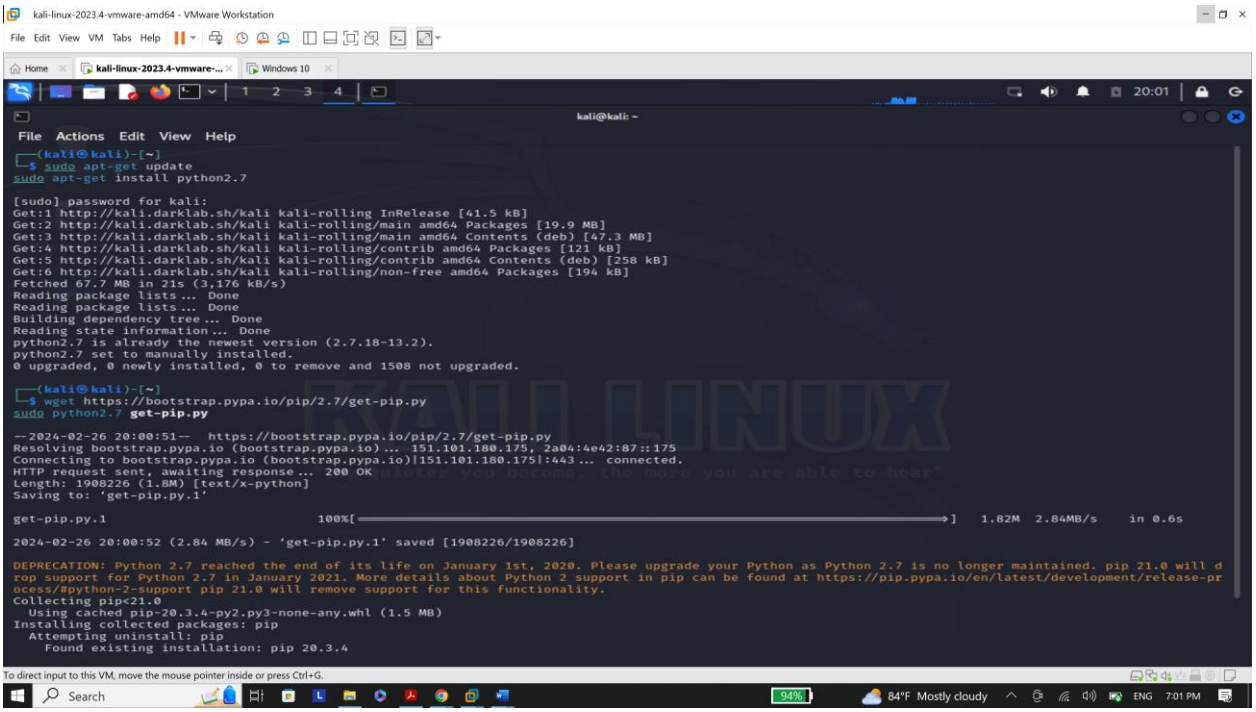

Figure B3. Kali Linux terminal showing installation and validation steps for Python 2.7 and pip as part of SSL/TLS stripping troubleshooting, performed to address legacy SSLStrip dependency requirements.

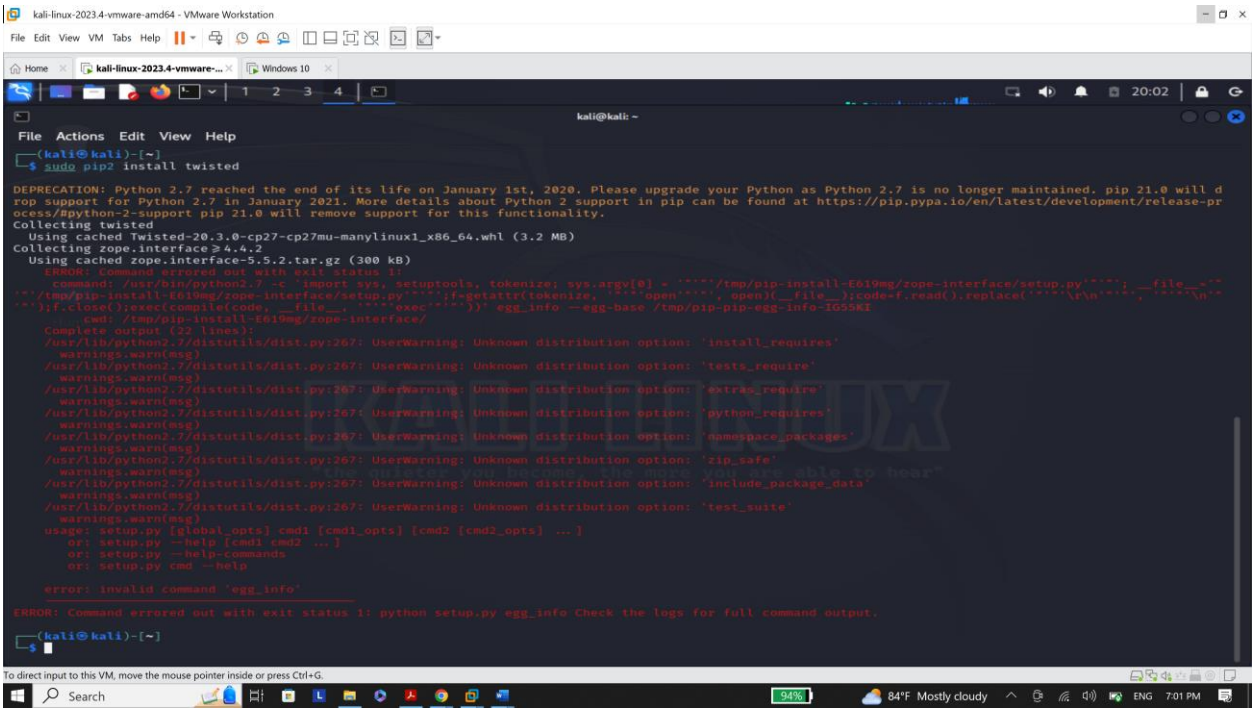

Figure B4. Kali Linux terminal showing a failed pip2 install twisted attempt during SSL/TLS stripping troubleshooting, including package build and setup.py errors that affected legacy SSLStrip dependency installation.

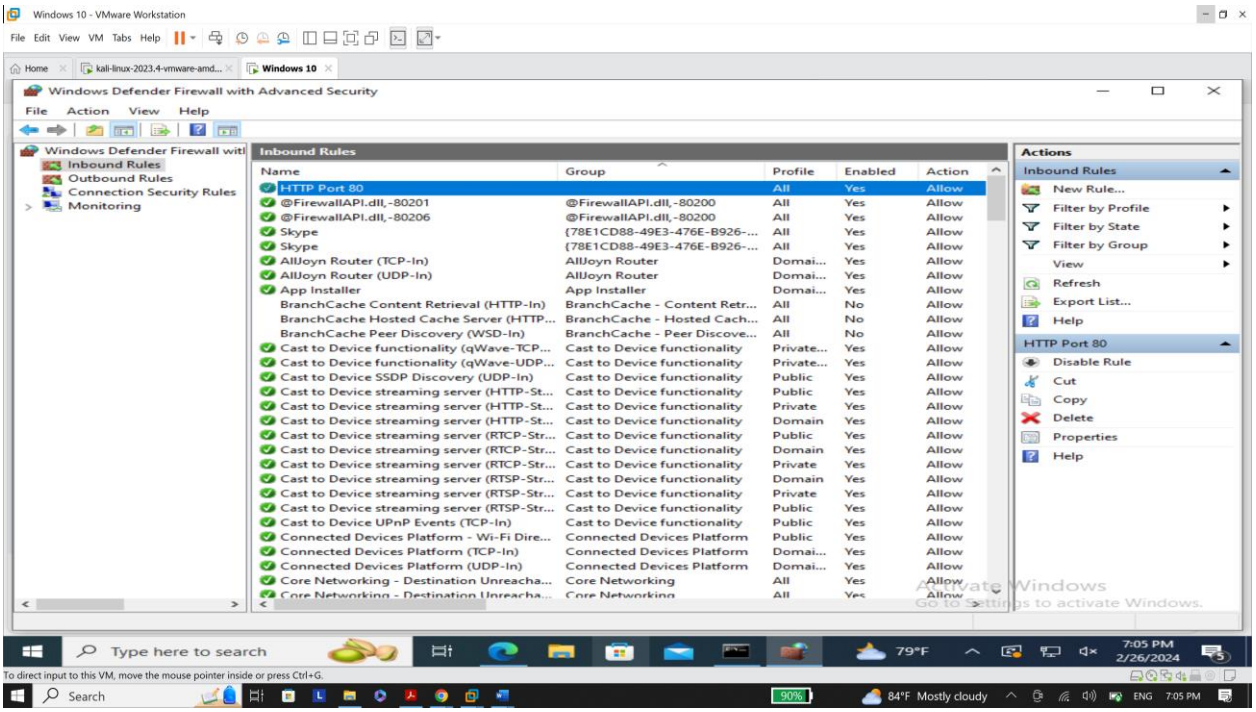

Figure B5. Windows Defender Firewall with Advanced Security showing a custom inbound rule for HTTP port 80 on the target Windows host, created during SSL/TLS stripping troubleshooting to test whether host firewall filtering was preventing interception traffic.

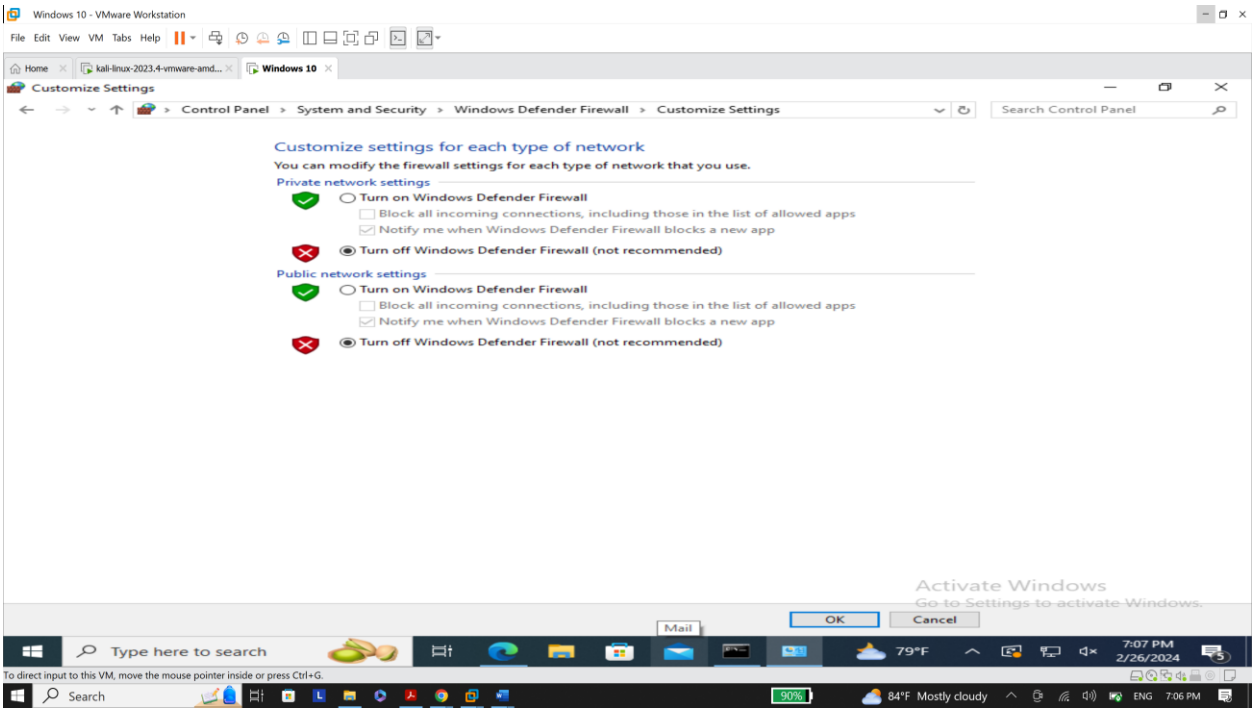

Figure B6. Windows firewall settings on the target host showing both private and public profile protections temporarily disabled during SSL/TLS stripping troubleshooting to determine whether host-based filtering was preventing interception traffic.